

Table of Contents

ANNEX C: IT OPERATIONS, SECURITY & DISASTER RECOVERY

Zarewa Aluminium and Plastics Ltd — System of Operations v3.0

Audience: IT administrators, MD (oversight), external IT contractors

C.1 IT GOVERNANCE

C.1.1 Responsibilities

Role	Responsibility
System Administrator (admin)	User management, deployments, backups, migrations
MD	Approve production changes, credential policy
Finance Manager	Period lock policy, integration API keys approval
All staff	Report incidents, protect credentials

C.1.2 Change Management

1. All production deployments follow change window (typically Sunday 02:00–06:00 WAT).
 2. Run `npm run test` and `npm run test:e2e` before deploy.
 3. Database migrations auto-run on startup — review `server/migrate.js` changelog before deploy.
 4. Rollback plan: restore database backup + previous API build.
-

C.2 REPOSITORY STRUCTURE

Repository

Zarewa-backend-main

Zarewa-frontend-main

Key backend paths

- `server/index.js` — API entry
- `server/httpApi.js` — route registration
- `server/auth.js` — roles and permissions
- `server/schemaSql.js` — database DDL
- `server/migrate.js` — incremental migrations
- `shared/` — cross-cutting business rules

Key frontend paths

- `src/App.jsx` — routing
 - `src/lib/moduleAccess.js` — RBAC UI
 - `src/lib/roleTrainingGuide.js` — onboarding
 - `src/lib/helpOperationalCatalog.js` — Zare knowledge (~1000 entries)
-

C.3 ENVIRONMENT CONFIGURATION

C.3.1 Required Production Variables

Variable

`NODE_ENV`

`ZAREWA_DB_URL` or MySQL vars

`SESSION_SECRET`

`COOKIE_SECURE`

`CORS_ORIGIN`

`ZAREWA_STATIC_DIR`

C.3.2 Security Variables

Variable

`ENFORCE_DUAL_CONTROL_PAYMENTS`

`DELIVERY_PAYMENT_GATE`

`SESSION_TIMEOUT_MINUTES`

`FAILED_LOGIN_LOCK_THRESHOLD`

C.3.3 Optional Features

Variable

`ZAREWA_AI_API_KEY`

`ZAREWA_EMPTY_SEED`

`VITE_API_BASE`

See `docs/ENVIRONMENT.md` and `docs/DEPLOYMENT.md` in backend repo.

C.4 DEPLOYMENT PROCEDURES

C.4.1 Combined Deployment

1. Build frontend: `cd Zarewa-frontend-main && npm run build`
2. Set `ZAREWA_STATIC_DIR` to `dist/` path
3. Start API: `cd Zarewa-backend-main && npm start`
4. Verify: `GET /api/health` returns 200

5. Verify: login page loads, bootstrap succeeds

C.4.2 Split Deployment

1. Deploy API to VM with HTTPS
2. Deploy frontend static files to CDN/host
3. Set VITE_API_BASE to API URL at frontend build time
4. Configure CORS_ORIGIN on API
5. Cookie SameSite=None; Secure=true for cross-origin

C.4.3 Health Checks

Endpoint

GET /api/health

GET /api/readyz

GET /api/livez

Monitor these every 60 seconds in production.

C.5 DATABASE ADMINISTRATION

C.5.1 Backup Schedule

Frequency

Daily

Weekly

Pre-deploy

C.5.2 Backup Procedure (MySQL)

```
mysqldump -u zarewa -p zarewa_prod > zarewa_backup_$(date +%Y%m%d).sql
```

Verify backup integrity weekly by restore to staging environment.

C.5.3 Migration Safety

1. Migrations run in transactions where supported
2. Tracked in zarewa_schema_migrations table
3. Never edit applied migrations — create new migration file
4. Test migrations on staging copy of production data first

C.5.4 Data Reset (NON-PRODUCTION ONLY)

Admin data reset available in Settings for development/training environments. **Never run data reset in production without MD written authorisation.**

C.6 SECURITY HARDENING CHECKLIST

Pre-Production (Mandatory)

- ☐ Replace all demo passwords
- ☐ Remove or disable demo viewer account
- ☐ HTTPS enabled with valid certificate
- ☐ COOKIE_SECURE=true
- ☐ ENFORCE_DUAL_CONTROL_PAYMENTS=1
- ☐ Strong SESSION_SECRET (32+ random bytes)
- ☐ Database credentials not in source code
- ☐ API not exposed to public internet without firewall
- ☐ Admin account limited to named individuals (not shared)
- ☐ Integration API keys rotated from defaults

Ongoing

- ☐ Quarterly credential rotation (admin, integration keys)
 - ☐ Review customPermissionAudit monthly
 - ☐ Review failed login attempts weekly
 - ☐ Patch Node.js dependencies monthly (npm audit)
 - ☐ Verify backup restore quarterly
-

C.7 INCIDENT RESPONSE

C.7.1 Severity Levels

Level

P1 Critical

P2 High

P3 Medium

P4 Low

C.7.2 P1 Response Procedure

1. Confirm outage via /api/health and user reports
2. Notify MD and department heads
3. Check server process, database connectivity, disk space
4. Review recent deployments — rollback if correlated
5. Communicate ETA to staff via official notice
6. Post-incident review within 48 hours

C.7.3 Data Integrity Incident

If suspected data corruption or unauthorised access:

1. Isolate affected system (read-only mode if available)
 2. Preserve audit logs — do not delete
 3. Notify MD and external auditor if required
 4. Restore from last known-good backup to staging
 5. Compare affected records; determine scope
 6. Correct through controlled reversals (not direct DB edits)
 7. Document in incident report
-

C.8 DISASTER RECOVERY

C.8.1 Recovery Time Objectives

Scenario

API server failure

Database corruption

Complete site loss

C.8.2 DR Procedure

1. Provision replacement server
2. Restore latest database backup
3. Deploy latest verified API + frontend builds
4. Update DNS to new server
5. Verify health checks and login
6. Run reconciliation: treasury balances, open quotations, production queue
7. Communicate restoration to all branches

C.8.3 Degraded Mode Operations

If ERP unavailable >4 hours during business hours:

1. BM authorises paper-only recording for receipts and GRNs
 2. **Single designated person** maintains paper log
 3. Double-entry prohibited on paper — one writer
 4. Full catch-up within 24 hours of restoration
 5. IT supervises catch-up to prevent duplicates
-

C.9 TESTING AND QA

C.9.1 Automated Test Suites

Suite

Unit tests

E2E tests

Key E2E specs: - sales-gate.spec.js — payment and price gates - sales-refund-finance-checklist.spec.js — refund dual control - access-control.spec.js — role restrictions - hr-smoke.spec.js — HR workflows - operational-sop-matrix-500.spec.js — SOP route coverage

C.9.2 Pre-Release Checklist

- ☐ All unit tests pass
 - ☐ E2E smoke pass on staging
 - ☐ Migration tested on staging DB copy
 - ☐ RBAC regression check (cashier cannot approve refund)
 - ☐ MD payroll gate still enforced
 - ☐ Backup taken immediately before deploy
-

C.10 INTEGRATION API

C.10.1 Read-Only GL Export

External accounting or BI tools may consume:

- GET /api/integration/v1/trial-balance — Bearer token auth
- GET /api/integration/v1/journals — journal register export

C.10.2 Key Management

1. Create key in Settings — Integrations
 2. Assign descriptive name and expiry
 3. Distribute securely to integration owner
 4. Rotate quarterly; revoke on staff departure
 5. Monitor usage in audit log
-

C.11 MONITORING AND LOGS

C.11.1 Application Logs

- API logs: stdout/stderr captured by process manager (pm2, systemd)
- Audit log: audit_log table — query via Settings or SQL
- HR audit: hr_audit_events table

C.11.2 Workspace Monitoring

/workspace/monitoring — admin/exec view of: - Active sessions - Office activity levels - Work item SLA breaches

C.12 USER SUPPORT TIERS

Tier

L1

L2

L3

Zare is L1 support — staff should try Zare “Tour this page” before escalating.

End of Annex C — IT Operations